

| SEGURANÇA DA INFORMAÇÃO

TEMA 1 – INTRODUÇÃO

No contexto da segurança da informação, a comunicação segura constitui um dos pilares centrais para garantir a proteção de dados sensíveis. A troca de informações em ambientes computacionais está sujeita a uma série de ameaças que podem comprometer a confidencialidade, a integridade e a autenticidade das mensagens. Dentre essas ameaças, os *malwares* desempenham papel proeminente, configurando-se como instrumentos recorrentes em ataques cibernéticos. Esta aula busca introduzir o estudante aos fundamentos da comunicação segura, associando-os à dinâmica das ameaças digitais contemporâneas.

TEMA 2 – PRINCÍPIOS DA COMUNICAÇÃO SEGURA

Em aulas anteriores, discutimos a importância de protegermos a informação como um ativo de grande valor. Nesse sentido, Lyra (2017, p. 3) destaca a importância da segurança da informação:

Sendo assim, temos a segurança da informação diretamente relacionada com a proteção de um conjunto de informações, para preservar o valor que possuem para um indivíduo ou uma organização, independentemente se estão associadas a sistemas computacionais, informações eletrônicas ou mesmo de seus sistemas de armazenamento.

A segurança da informação, como vimos anteriormente, fundamenta-se em um conjunto de princípios essenciais, entre os quais se destaca a tríade CIA (confidencialidade, integridade e disponibilidade) complementada pelos atributos de autenticidade, não repúdio e legalidade.

2.1 Incidente de segurança

Podemos definir como incidente de segurança algum evento que possa comprometer algum dos princípios relacionados anteriormente, que possa levar à interrupção das atividades relacionadas ao uso da informação, independentemente da dimensão, seja um evento isolado ou uma série de eventos que possam comprometer ou prejudicar, ameaçando a segurança da informação.

Nesse contexto, destacam-se as ameaças, os ataques, os fatores naturais, as greves, as manifestações, entre outras ações que possam afetar direta ou indiretamente a disponibilidade e a integridade das informações.

2.2 Garantia de segurança

A garantia da segurança da informação consiste na adoção de medidas que assegurem ao usuário a confiabilidade do ambiente em que os dados estão armazenados. No contexto do desenvolvimento de software, essa garantia deve ser perceptível e verificável pelo próprio usuário, mediante a realização de testes cujos resultados possam ser auditados por laboratórios independentes.

Conforme a ISO/IEC 15408, a garantia de segurança baseia-se em três diretrizes centrais: especificar claramente os protocolos de segurança; desenvolver conforme essas especificações; e realizar testes que verifiquem a conformidade dos requisitos. Nesse contexto, Albuquerque e Ribeiro (2002) destacam que tais testes e especificações, validados inclusive por laboratórios independentes, constituem evidências fundamentais da eficácia dos mecanismos implementados para assegurar a proteção esperada.

TEMA 3 – MODELOS DE AMEAÇAS E VETORES DE ATAQUE

Em segurança da informação, a distinção entre modelos de ameaça e vetores de ataque é fundamental para a análise sistemática dos riscos e para o desenho de estratégias de mitigação eficientes. Modelos de ameaça são descrições estruturadas das possíveis fontes de risco, incluindo atores mal-intencionados, sua motivação, capacidades técnicas e objetivos de ataque.

Por sua vez, vetores de ataque correspondem aos caminhos ou meios específicos pelos quais esses agentes exploram vulnerabilidades em sistemas, redes ou pessoas para atingir seus objetivos maliciosos. Esses vetores incluem: vetores de rede; vetores de aplicação; vetores humanos; vetores físicos.

Compreender os conceitos é essencial para a adoção de uma abordagem de gestão de riscos alinhada às normas ISO/IEC 27001 (ISO, 2022a) e NIST SP 800-30 (NIST, 2012b), que exigem a identificação, a avaliação e o tratamento de riscos antes da implementação de controles de segurança.

3.1 Modelos de ameaça

Podemos definir como modelos de ameaça os possíveis ataques que podem ser executados sobre um sistema de informação, e sua compreensão nos permite identificar vulnerabilidades e pontos de atenção do sistema, possibilitando a proposição de protocolos e sistemas de segurança mais eficazes. Dentre os diversos modelos de ameaça, destacam-se os modelos STRIDE, PASTA e DREAD. A seguir, veremos o que representam cada um desses modelos.

3.1.1 Modelo STRIDE

O modelo STRIDE, segundo Isaacs (2023), tem foco em seis principais fatores, cujas iniciais formam seu acrônimo: autenticidade (*spoofing*); integridade (*tampering*); não repúdio (*repudiation*); confidencialidade (*information disclosure*); disponibilidade (*denial of service*); autorização (*elevation of privilege*). Isto é, o modelo se preocupa em investigar se existe alguma fragilidade nesses seis quesitos, a fim de evitar uma violação do sistema e o acesso indevido às informações a serem protegidas.

Segundo Shostack (2014, p. 61, tradução nossa), “usar o STRIDE é mais como uma técnica de elicitación, com a expectativa de que você ou sua equipe entendam a estrutura e saibam como usá-la” . O quadro a seguir resume os benefícios em utilizar o modelo STRIDE:

Quadro 1 - Modelo STRIDE

Benefícios	
Flexibilidade	STRIDE é uma estrutura adaptável e aplicável em diversos setores e contextos, não se restringindo a casos de uso específicos.
Análise de possíveis falhas	Ajuda a responder à pergunta “O que pode dar errado?” do framework de Shostack, mapeando vetores e técnicas de ataque.
Priorização de riscos	Permite ordenar ameaças e controles conforme sua criticidade, facilitando a gestão de riscos e recursos.
Redução de violações	Quando corretamente aplicado, o STRIDE contribui para a prevenção de falhas e violações de segurança.

Fonte: Elaborado com base em Addy, 2023b.

O STRIDE é frequentemente utilizado em conjunto com diagramas de fluxo de dados (DFDs) para mapear ameaças em componentes específicos de

um sistema, como API (Application Programming Interface – Interface de Programação de Aplicações), bancos de dados, interfaces de usuário e servidores. Entretanto, assim como qualquer modelo, existem limitações que devem ser consideradas, conforme podemos verificar no Quadro 2:

Quadro 2 - Limitações do modelo STRIDE

Limitações	
Recurso intensivo	A aplicação completa do STRIDE em sistemas complexos demanda tempo e esforço considerável.
Análise estática	O foco em arquitetura e design pode deixar de lado ameaças dinâmicas ou em tempo real.
Subjetividade na avaliação	A análise de impacto e probabilidade pode variar conforme a equipe, tornando os resultados menos consistentes.
Manutenção contínua	O STRIDE requer revisões periódicas para refletir mudanças no sistema ou nas ameaças.
Foco restrito a software	Foi originalmente concebido para desenvolvimento de software, o que limita sua aplicabilidade em domínios não digitais.

Fonte: Elaborado com base em Addy, 2023b.

Vale destacar que o modelo STRIDE, embora amplamente reconhecido como uma abordagem estruturada de modelagem de ameaças, não substitui os testes práticos de segurança. Por se tratar de uma técnica analítica baseada na arquitetura do sistema, sua aplicação não elimina a necessidade de testes empíricos, como testes de penetração, auditorias de código-fonte e validações em tempo de execução, os quais são essenciais para a identificação de vulnerabilidades contextuais ou emergentes.

3.1.2 Modelo PASTA

O modelo PASTA, acrônimo de *Process for Attack Simulation and Threat Analysis* (processos de simulação de ataques e análises de ameaças), proposto por Tony Uceda Vélez e Marco Morana em 2015, oferece uma abordagem estruturada e interativa para identificar, analisar e mitigar ameaças cibernéticas de forma abrangente e estratégica. (Addy, 2023a)

O modelo consiste na análise das ameaças em sete etapas, conforme Kirtley (2022): definição de objetivos; definição de escopo técnico; decomposição de aplicação; análise de ameaças; análise de vulnerabilidades e fraquezas; modelagem de ataque; análise de risco e impacto.

A estruturação do PASTA em fases sequenciais e logicamente delimitadas favorece a aplicação prática da modelagem de ameaças, especialmente em ambientes complexos. Ao estabelecer instruções claras para cada estágio, o modelo permite que analistas e equipes de segurança decomponham o problema em partes gerenciáveis, reduzindo a complexidade do processo como um todo e promovendo uma abordagem sistemática, orientada tanto à avaliação técnica quanto ao impacto nos objetivos do negócio.

3.1.3 Modelo DREAD

O modelo DREAD, desenvolvido pela Microsoft, é uma metodologia de modelagem de ameaças que visa quantificar e priorizar riscos associados a vulnerabilidades em sistemas de informação. Fundamentado em cinco critérios, dano, reprodutibilidade, explorabilidade, usuários afetados e descobribilidade, o modelo atribui pontuações em escala de 0 a 10, cuja média aritmética compõe um índice de risco. Essa abordagem permite avaliar a severidade das ameaças e orientar decisões quanto à urgência de mitigação (Meier et al., 2003; Microsoft, 2025). Ainda que esse método possua um caráter subjetivo, sua natureza semiquantitativa permite a comparação sistemática entre diferentes ameaças e a alocação mais racional de recursos de segurança, como podemos verificar no quadro a seguir:

Quadro 3 - Modelo DREAD

Componente	Descrição
Dano Potencial (Damage Potential)	Refere-se à gravidade do impacto causado pela exploração da vulnerabilidade, incluindo perdas financeiras, vazamentos de dados ou paralisação de serviços.
Reprodutibilidade (Reproducibility)	Mede o grau de facilidade com que o ataque pode ser repetido com sucesso por terceiros.
Explorabilidade (Exploitability)	Avalia o esforço, nível de conhecimento e recursos necessários para explorar a vulnerabilidade.
Usuários Afetados (Affected Users)	Considera a proporção de usuários impactados direta ou indiretamente pela exploração da ameaça.
Descobribilidade (Discoverability)	Indica a probabilidade de que a vulnerabilidade seja detectada por um atacante, considerando fatores como documentação, exposição e facilidade de análise.

Fonte: Elaborado com base em Microsoft, 2025.

A aplicação do modelo DREAD à segurança da informação oferece vantagens relevantes, como sua padronização metodológica, que favorece

análises consistentes e comparações entre diferentes ameaças (Purestorage, 2024). A quantificação dos riscos em escalas numéricas, segundo Shostack (2014), contribui para tornar as ameaças mais tangíveis, favorecendo decisões mais embasadas e facilitando o diálogo entre áreas técnicas e administrativas quanto à priorização de ações e alocação de recursos.

Segundo Weissman (2024), um ponto crítico a ser ressaltado refere-se à ausência de ponderação entre os critérios, visto que os cinco componentes são tratados com pesos iguais. Dessa forma, a aplicação do DREAD deve ser conduzida com critérios técnicos rigorosos, complementada por outras abordagens e revisada periodicamente, a fim de garantir a robustez, a confiabilidade e a efetividade das estratégias de segurança adotadas.

O quadro a seguir apresenta um comparativo entre os três modelos estudados - vale ressaltar que todos são importantes e podem ser integrados:

Quadro 4 - Comparativo entre modelos

Critério	STRIDE	PASTA	DREAD
Origem	Microsoft (Security Development Lifecycle – SDL)	Tony UcedaVélez e Marco M. Morana (2012)	Microsoft (usado originalmente com STRIDE)
Abordagem	Modelo qualitativo e categórico de identificação de ameaças	Modelo estruturado em sete etapas, baseado em análise de risco e impacto no negócio	Modelo semiquantitativo de priorização de riscos com base em pontuações
Objetivo principal	Identificar categorias de ameaças associadas a ativos e fluxos de dados	Realizar uma análise de ameaças centrada em riscos e contexto organizacional	Priorizar e classificar ameaças de acordo com critérios de impacto, frequência e impacto percebido
Componentes centrais	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege	7 etapas (do entendimento do negócio à modelagem de ataques e mitigação de riscos)	Damage Potential, Reproducibility, Exploitability, Affected Users, Discoverability
Vantagens	- Simples de aplicar- Ótimo para identificar vetores técnicos- Apoiado por diagramas (DFD)	- Abrange aspectos técnicos e de negócios- Baseado em risco e impacto- Método iterativo e detalhado	- Permite quantificação do risco- Facilita a comunicação técnica/gerencial- Apoia decisões
Limitações	- Foco técnico e em software- Pouco voltado ao impacto de negócios- Não quantifica riscos	- Processo mais complexo e demorado- Requer equipe multidisciplinar- Nem sempre fácil de operacionalizar	- Alta subjetividade nas pontuações- Pode simplificar cenários complexos- Menos replicável
Aplicabilidade	Análise técnica de sistemas de software e aplicações	Ambientes organizacionais complexos com múltiplos atores e ativos críticos	Ambientes que exigem priorização rápida de falhas em sistemas já identificados
Relação entre os modelos	Pode ser usado como base para identificação de ameaças a serem detalhadas em PASTA ou priorizadas em DREAD	Pode incorporar resultados de STRIDE na etapa 4 (análise de ameaças) e usar DREAD para priorizar riscos identificados	Frequentemente utilizado como complemento ao STRIDE, para quantificar e ordenar ameaças

Esses três modelos não são excludentes, mas complementares, podendo ser combinados conforme os objetivos da organização, o que favorece uma abordagem robusta, abrangendo identificação, contextualização e priorização de ameaças em ambientes que exigem elevada maturidade em segurança da informação.

3.2 Vetores de ataque

No âmbito da segurança da informação, vetores de ataque designam os métodos empregados por agentes maliciosos para comprometer sistemas e violar os pilares da confidencialidade, integridade e disponibilidade (Pronnus, 2023). Entre as técnicas mais recorrentes se destacam *phishing*, *malwares*, exploração de vulnerabilidades, engenharia social e ataques direcionados a serviços como DNS, APIs e aplicações web (Akamai, 2025). Tais ofensivas podem ser classificadas como ativas, quando provocam dano direto ou passivas, quando visam à obtenção furtiva de dados, a exemplo de escutas e interceptações de tráfego (Pereira, 2005; Cloudflare, 2025; Fortinet, 2025).

Complementarmente, o conceito de *superfície de ataque* representa o conjunto de pontos vulneráveis passíveis de exploração em uma organização, abrangendo tanto recursos físicos e digitais quanto o fator humano. Quanto maior e mais exposta essa superfície, maior será a probabilidade de sucesso de um ataque cibernético.

TEMA 4 – TIPOS DE MALWARE E CICLO DE INFECÇÃO

Com o crescimento exponencial da infraestrutura digital, as ameaças associadas à segurança cibernética também se intensificaram, sendo o *malware* uma das ferramentas mais recorrentes utilizadas por agentes maliciosos.

Malware (abreviação de *malicious software*) designa qualquer código executável projetado para comprometer a integridade, a confidencialidade ou a disponibilidade de um sistema computacional. Sua atuação pode ocorrer em computadores pessoais, dispositivos móveis, redes de computadores ou servidores corporativos.

Entre as formas mais comuns de *malware*, Aslan e Samet (2020) destacam vírus, *worms*, cavalos de Troia, *rootkits* e os *ransomwares*, cada qual com características específicas de propagação, ocultação e impacto.

4.1 Tipos de *malware*

Em um panorama evolutivo, é possível distinguir duas gerações principais de *malware*: os *malwares* tradicionais e os *malwares* de nova geração, conforme podemos ver no quadro a seguir:

Quadro 5 - Comparativo entre gerações de *malwares*

Parâmetro de Comparação	Tradicional	Nova Geração
Nível de implementação	codificação simples	codificação complexa
Estado dos comportamentos	estático	dinâmico
Proliferação	cada cópia é similar	cada cópia é diferente
Forma de disseminação	usa extensão .exe	usa também diferentes extensões
Permanência no sistema	temporária	persistente
Interação com processos	poucos processos	múltiplos processos
Uso de técnicas de ocultação	nenhum	sim
Tipo de ataque	geral	direcionado
Desafio defensivo	fácil	difícil
Dispositivos-alvo	computadores em geral	muitos tipos de dispositivos

Fonte: Elaborado com base em Aslan e Samet, 2020.

Os *malwares* tradicionais, de estrutura simples e sem técnicas avançadas de ocultação, contrastam com as ameaças da nova geração, caracterizadas por sua complexidade e capacidade de operar em modo *kernel*, contornando defesas nativas, como antivírus e *firewalls*. Diante desse cenário, Alsmadi e Alqudah (2021) destacam a importância de compreender profundamente suas funções e mecanismos de evasão, a fim de estruturar estratégias eficazes de prevenção, detecção e resposta diante dos atuais riscos cibernéticos.

4.2 Ciclo de infecção

A literatura especializada reconhece, de forma consensual a relevância de se compreender os mecanismos de infecção e transmissão dessas ameaças (Aslan; Samet, 2020; Alsmadi; Alqudah, 2021; Aboaoja et al., 2022). Nesse cenário, abordagens baseadas em *deep learning* e *machine learning* têm sido amplamente empregadas para análise e detecção (Bensaoud; Kalita; Bensaoud, 2024).

A infecção ocorre com a introdução do *malware* no sistema-alvo, utilizando vetores de diversas naturezas e, conforme o NIST SP 800-83, Rev.1 (Souppaya; Scarfone, 2005), a escolha desse vetor representa uma decisão estratégica do agente malicioso, baseada na análise da superfície de ataque da vítima. Ferreira e Araújo (2008, p. 93) destacam:

Usuários sempre serão usuários. Ainda que a organização ofereça uma máquina rápida, repleta de memória, certamente tentará instalar seus próprios programas. E, por isso, impedir que usuários acrescentem software não autorizado em seus computadores de mesa ou notebooks se tornou uma preocupação comum entre os gestores de TI e de Segurança da Informação.

A fase de execução do *malware* ativa mecanismos que garantem sua instalação e operação autônoma no sistema, conforme descrito pelo NIST SP 800-61, Rev.2 (NIST, 2012a). Em seguida, o código malicioso estabelece persistência por meio de modificações no sistema, como alterações no registro, agendamento de tarefas e elevação de privilégios, com o intuito de evitar a detecção por antivírus e *scanners* de integridade. Uma vez estabilizado, o *malware* costuma se conectar a servidores de comando e controle (C&C) para receber instruções, furtar dados ou se atualizar, sendo o monitoramento dessas conexões um ponto crítico para contenção, segundo a ISO/IEC 27002:2022 (ISO, 2022b).

Na sequência, executa-se a carga útil, que pode incluir ações como criptografia de arquivos, espionagem, interceptação de dados ou sabotagem. Por fim, técnicas avançadas de evasão, como encriptação, mutação de código e camuflagem em processos legítimos, tornam difícil a detecção, sendo comum o uso de *packers* e *crypters*, uma tendência já alertada pelo NIST SP 800-83 Rev.1 (NIST, 2005).

Dessa forma, o ciclo de infecção por *malware* revela-se como um processo multifásico e adaptativo, cuja compreensão é indispensável à implementação de controles coerentes com as diretrizes normativas e à proteção dos ativos informacionais em contextos organizacionais.

TEMA 5 – MALWARE COMO FERRAMENTA DE COMPROMETIMENTO

Na era digital, o *malware* tornou-se uma das principais ferramentas utilizadas por agentes maliciosos para comprometer sistemas, redes e dados sensíveis. Os agentes exploram múltiplos vetores de infecção: *e-mails phishing*, *downloads* falsos, vulnerabilidades de sistemas, dispositivos removíveis e técnicas de engenharia social. A sofisticação crescente dessas ameaças, aliada à sua capacidade de se camuflar e persistir no ambiente infectado, representa um desafio complexo para a defesa das infraestruturas digitais.

5.1 Tipos, técnicas e evolução do *malware*

Malware (do inglês *malicious software*) é um termo genérico usado para designar qualquer software ou código malicioso criado para infiltrar, danificar ou controlar de forma não autorizada sistemas computacionais (IBM, 2022). Seu objetivo principal é comprometer a segurança dos dispositivos, roubando informações, interrompendo serviços ou assumindo o controle das máquinas infectadas. Entender suas características e seu funcionamento é fundamental para profissionais de segurança da informação, pois ele representa uma das ameaças digitais mais persistentes e versáteis na atualidade.

5.1.1 Tipos comuns de *malware*

Os *malwares* manifestam-se em diversas formas, cada qual com estratégias específicas de infecção e propagação. Conforme o NIST (2013), destacam-se: vírus, que dependem da ação do usuário; *worms*, autônomos e rápidos; *trojans*, que se disfarçam como softwares legítimos; *ransomwares*, que sequestram dados via criptografia; *spywares*, voltados à coleta furtiva de informações; e *bots/botnets*, usados para controle remoto e ataques em larga escala.

5.1.2 Técnicas de infecção e propagação

O *malware* utiliza uma combinação de vetores e técnicas para se infiltrar e se propagar nos sistemas. Para evitar a detecção, muitos *malwares* empregam métodos sofisticados, como *rootkits*, que atuam no nível do sistema operacional, *bootkits*, que afetam o processo de inicialização, e técnicas *fileless*, que não deixam rastros em arquivos físicos. Ainda, utilizam criptografia e polimorfismo para alterar seu código, dificultando a identificação por antivírus, além de desabilitar ferramentas de segurança ou manipular registros do sistema.

5.1.3 Evolução do *malware*

Desde os primeiros vírus criados nos anos 1980, o *malware* evoluiu significativamente, acompanhando os avanços tecnológicos e o crescimento da internet. Inicialmente, o objetivo principal era a demonstração técnica ou causar danos superficiais, como propagação e exibição de mensagens.

Com o avanço da conectividade, passaram a ser utilizadas propagandas maliciosas e ataques automatizados em larga escala. Na última década, o *malware* tornou-se componente central do cibercrime organizado, com foco em lucro financeiro, espionagem empresarial e sabotagem cibernética.

Exemplos emblemáticos, como o *worm* WannaCry, que causou um surto global de *ransomware*, e o sofisticado Stuxnet, que atacou infraestruturas industriais, mostram os diferentes perfis e níveis de complexidade dos ataques.

Na contemporaneidade digital, o desenvolvimento e a disseminação de *malwares* constituem um fenômeno multifacetado, cujos objetivos transcendem o mero vandalismo informático; os agentes maliciosos operam com motivações diversas, entre as quais a vantagem financeira se sobressai como uma das mais recorrentes. (Stancik, 2017; Aslan; Samet, 2019)

TEMA 6 – PREVENÇÃO E DETECÇÃO DE AMEAÇAS DIGITAIS

Percebemos que as organizações dependem cada vez mais de ambientes digitais, e a prevenção e a detecção de ameaças digitais emergem como pilares fundamentais para garantir a integridade, a confidencialidade e a disponibilidade dos ativos digitais. De acordo com Moreira, Razzolini Filho e Adrião (2023), as tecnologias de vigilância são responsáveis por gerar informações relevantes sobre os indivíduos, estabelecendo relações identitárias entre as pessoas e suas representações informacionais, resultantes dos processos de agregação de dados.

A detecção de ameaças consiste no monitoramento contínuo de sistemas, redes, *endpoints* e aplicações para identificar comportamentos anômalos e potenciais riscos em tempo real, permitindo uma rápida investigação e resposta. Já a prevenção se fundamenta no fortalecimento das defesas por meio de controles de acesso rigorosos, atualizações constantes, treinamentos e adoção de tecnologias, como *firewalls*, antivírus, sistemas de detecção e resposta (TDR/EDR) e inteligência contra ameaças.

6.1 Fundamentos da prevenção em segurança digital

A prevenção em segurança digital fundamenta-se em princípios estruturantes que orientam a proteção de sistemas e dados diante de acessos indevidos e ameaças cibernéticas. Logo, a efetividade da prevenção depende de

um conjunto articulado de práticas técnicas, administrativas e comportamentais. A formulação de políticas organizacionais claras, a avaliação contínua de riscos, a atualização constante dos sistemas e o controle rigoroso de acessos são medidas indispensáveis (Ferreira; Araújo, 2008).

Recursos tecnológicos, como antivírus, *firewalls*, sistemas de detecção e prevenção de intrusões (IDS/IPS), aliados a soluções de monitoramento contínuo, funcionam como barreiras adicionais capazes de bloquear, mitigar ou responder rapidamente a incidentes de segurança.

6.2 Treinamento, conscientização e fator humano

A segurança digital não depende apenas de soluções técnicas; ela depende, de maneira significativa, da atuação consciente dos usuários que interagem com os sistemas. Pereira (2005, p. 76), quanto a essa questão, apresenta:

Dado o elevado número e diversidade de possíveis ataques e ameaças, torna-se necessária uma resposta que assente muito na prevenção e não apenas no combate. Além disso, nessa estratégia de prevenção, os recursos humanos são um elemento-chave e qualquer plano de segurança ou proposta de boas práticas terá que ter isso em linha de conta.

Nesse contexto, o fator humano emerge simultaneamente como uma das principais vulnerabilidades e uma das mais potentes linhas de defesa. A eficácia das estratégias de prevenção está diretamente relacionada à capacidade de promover treinamento contínuo e conscientização em segurança da informação, consolidando comportamentos alinhados às boas práticas de proteção cibernética.

Entre os temas prioritários para ações de conscientização destacam-se: o reconhecimento de tentativas de *phishing*, *smishing* e *spear phishing*; o cuidado com mídias removíveis, redes públicas e downloads; a gestão adequada de senhas e a adoção de autenticação multifator; bem como a compreensão das normas internas e da responsabilidade compartilhada sobre os ativos digitais.

Investimentos nessa dimensão produzem benefícios tangíveis, como a redução de incidentes causados por falhas humanas, o fortalecimento da cultura organizacional de segurança, a maior resistência a ataques baseados em engenharia social e a melhoria da capacidade de resposta diante de ameaças emergentes.

6.3 Resposta a incidentes e mitigação

A resposta a incidentes configura-se como um dos pilares centrais da segurança da informação, sendo determinante para mitigar os impactos decorrentes de ataques cibernéticos, violações de acesso e demais eventos adversos que comprometam a integridade dos ativos digitais. Sua eficácia, no entanto, está diretamente vinculada à existência de processos estruturados, à integração entre equipes especializadas e ao uso estratégico da tecnologia.

O processo de resposta a incidentes é fundamentado em etapas bem definidas, iniciando-se pela fase de preparação, na qual se estabelecem políticas, constituem-se equipes especializadas, como os Computer Security Incident Response Teams (CSIRTs) (West-Brown; Stikvoort; Kossakowski, 1998), e são realizados treinamentos voltados à atuação rápida e coordenada.

A resposta a incidentes de segurança compreende um ciclo estruturado de ações, que se inicia com a contenção da ameaça, por meio do isolamento de sistemas afetados e da proteção de ativos sensíveis. Em seguida, a fase de erradicação visa à remoção da causa raiz, com a exclusão de *malwares*, a correção de vulnerabilidades exploradas e a aplicação de atualizações. A recuperação ocorre posteriormente, com a restauração segura dos sistemas e dados por meio de backups validados, assegurando a higidez do ambiente antes da retomada das operações.

Encerrado o ciclo técnico, a análise pós-incidente assume papel estratégico, ao registrar os procedimentos adotados, extrair lições aprendidas e orientar melhorias contínuas nos controles e nos planos de resposta. Em todas essas etapas, a salvaguarda do acesso e da informação é imperativa, exigindo medidas como revogação de credenciais, redefinição de senhas, revisão de permissões e adoção de autenticação robusta.

REFERÊNCIAS

ABOAOJA, F. A. et al. Malware Detection Issues, Challenges, and Future Directions: A Survey. **Applied Sciences**, v. 12, n. 17, p. 8482, 2022.

ADDY, C. A. Threat Modeling Methodology: PASTA. **IriusRisk**, 29 Sept. 2023a. Disponível em: <<https://www.irusrisk.com/resources-blog/pasta-threat-modeling-methodologies>>. Acesso em: 26 jun. 2025.

_____. Threat Modeling Methodology: STRIDE. **IriusRisk**, 29 Sept. 2023b. Disponível em: <https://www.irusrisk.com/resources-blog/threat-modeling-methodology-stride>. Acesso em: 26 jun. 2025.

AKAMAI. **O que é um vetor de ataque?** Disponível em: <<https://www.akamai.com/pt/glossary/what-is-attack-vector>>. Acesso em: 30 jun. 2025.

ALBUQUERQUE, R.; RIBEIRO, B. **Segurança no desenvolvimento do software**: como desenvolver sistemas seguros e avaliar a segurança de aplicações desenvolvidas com base na ISO 15.408. Rio de Janeiro: Campus, 2002.

ALSMADI, T.; ALQUDAH, N. A survey on malware detection techniques. In: INTERNATIONAL CONFERENCE ON INFORMATION TECHNOLOGY (ICIT), 10., 2021, Amman. **Proceedings...** New York: Institute of Electrical and Electronics Engineers (IEEE), 2021. p. 371-376.

ASLAN, O.; SAMET, R. A Comprehensive Review on Malware Detection Approaches. **IEEE Access**, [S.l.], v. 8, p. 6249-6271, 2020. Disponível em: <<http://dx.doi.org/10.1109/access.2019.2963724>>. Acesso em: 18 ago. 2025.

BENSAOUD, A.; KALITA, J.; BENSAOUD, M. A survey of malware detection using deep learning. **Machine Learning With Applications**, v. 16, p. 100546, 2024.

CLOUDFLARE. **O que é um vetor de ataque?** Disponível em: <<https://www.cloudflare.com/pt-br/learning/security/glossary/attack-vector>>. Acesso em: 30 jun. 2025.

FERREIRA, F. N. F.; ARAÚJO, M. T. de. **Política de Segurança da Informação**: guia prático para elaboração e implementação. 2. ed. rev. e ampl. Rio de Janeiro: Ciência Moderna, 2008.

FORTINET. **What Is An Attack Vector?** Disponível em: <<https://www.fortinet.com/resources/cyberglossary/attack-vector>>. Acesso em: 30 jun. 2025.

IBM. **O que é malware?** 2022. Disponível em: <<https://www.ibm.com/br-pt/think/topics/malware>>. Acesso em: 16 jun. 2025.

ISAACS, A. The STRIDE Threat Model – A Comprehensive Guide. **Aptori**, 9 July 2023. Disponível em: <<https://www.aptori.com/blog/the-stride-threat-model-a-comprehensive-guide>>. Acesso em: 26 jun. 2025.

ISO – The International Organization for Standardization. The International Electrotechnical Commission (IEC). **ISO/IEC 27001:2022** – Information security, cybersecurity and privacy protection – Information security management systems – Requirements. Geneva: ISO/IEC, 2022a.

_____. **ISO/IEC 27002:2022** – Information security, cybersecurity and privacy protection – Information security controls. Geneva: ISO/IEC, 2022b.

KIRTLEY, N. **PASTA Threat Modeling**. [S.l.], 24 July 2022. Disponível em: <<https://threat-modeling.com/pasta-threat-modeling>>. Acesso em: 27 jun. 2025.

LYRA, M. R. **Segurança e auditoria em sistemas da informação**. 2. ed. rev. e ampl. Rio de Janeiro. Ciência Moderna, 2017.

MEIER, J. D. et al. **Improving Web Application Security**: threats and countermeasures. Redmond: Microsoft Press, 2003.

MICROSOFT. **Modelagem de ameaças para controladores de software**. [S.l.], 30 abr. 2025. Disponível em: <<https://learn.microsoft.com/pt-br/windows-hardware/drivers/driversecurity/threat-modeling-for-drivers>>. Acesso em: 27 jun. 2025.

MOREIRA, A. L. D.; RAZZOLINI FILHO, E.; ADRIÃO, M. C. Vigilância do fluxo informacional e privacidade no ambiente digital. **RDBCI**, Campinas, v. 21, p. e023012, 2023. Universidade Estadual de Campinas. <http://dx.doi.org/10.20396/rdbci.v21i00.8671505>.

NIST – National Institute of Standards and Technology. **Computer Security Incident Handling Guide**: NIST Special Publication (SP) 800-61, Revision 2. Gaithersburg, MD: NIST, 2012a.

_____. **Glossary of Key Information Security Terms**. NISTIR 7298, Revision 2. Gaithersburg, MD: NIST, 2013. Disponível em: <<https://doi.org/10.6028/NIST.IR.7298r2>>. Acesso em: 29 jul. 2025.

_____. **Guide to Malware Incident Prevention and Handling**: NIST Special Publication 800-83, Revision 1. Gaithersburg, MD: NIST, 2005.

_____. **NIST SP 800-30 Rev. 1**: Guide for Conducting Risk Assessments. Gaithersburg, MD: NIST, 2012b. Disponível em: <<https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>>. Acesso em: 17 jul. 2025.

PEREIRA, P. J. F. Segurança da informação digital. **Cadernos BAD**, n. 1, p. 66-80, 2005. Disponível em: <<https://publicacoes.bad.pt/revistas/index.php/cadernos/article/view/822>>. Acesso em: 18 ago. 2025.

PRONNUS. **Entendendo vetores de ataque em segurança da informação**. Joaçaba, 7 nov. 2023. Disponível em: <<https://pronnus.com.br/blog/entendendo-os-vetores-de-ataque-em-seguranca-da-informacao-como-proteger-seus-dados>>. Acesso em: 30 jun. 2025.

PURESTORAGE. **What Is the DREAD Threat Model?** [S.l.], 2024. Disponível em: <<https://www.purestorage.com/knowledge/dread-threat-model.html>>. Acesso em: 27 jun. 2025.

SHOSTACK, A. **Threat Modeling**: Designing for Security. Hoboken: John Wiley & Sons, 2014.

SOUPPAYA, M.; SCARFONE, K. **Nist Special Publication 800-83 Revision 1**: Guide to Malware Incident Prevention and Handling for Desktops and Laptops. Gaithersburg: National Institute of Standards and Technology, 2013. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-83r1.pdf#page=1.40&gsr=0>>. Acesso em: 16 jun. 2025.

STANCIK, P. **No more pointless password requirements**. 2017. Disponível em: <<https://www.welivesecurity.com/2017/05/03/no-pointless-password-requirements>>. Acesso em: 26 jul. 2025.

WEISSMAN, H. L. Modelagem de ameaças com STRIDE e DREAD. **iTexto**, 28 out. 2024. Disponível em: <<https://insights.itexto.com.br/modelagem-de-ameacas-com-stride-e-dread>>. Acesso em: 27 jun. 2025.

WEST-BROWN, M.; STIKVOORT, D.; KOSSAKOWSKI, K. P. **Handbook for computer security incident response teams (CSIRTs)**. Pittsburgh: Carnegie Mellon Software Engineering Institute, 1998. Disponível em: <<https://cisre.egr.uh.edu/wp-content/uploads/2023/09/csirt.pdf>>. Acesso em: 18 ago. 2025.